

Cyber Threats and Vulnerabilities 2

Executive Summary

The grcPortal has successfully implemented a comprehensive enterprise vulnerability management and advanced threat analysis system. All required components are fully functional, including automated testing frameworks, custom assessment tools, performance monitoring, and detailed documentation.

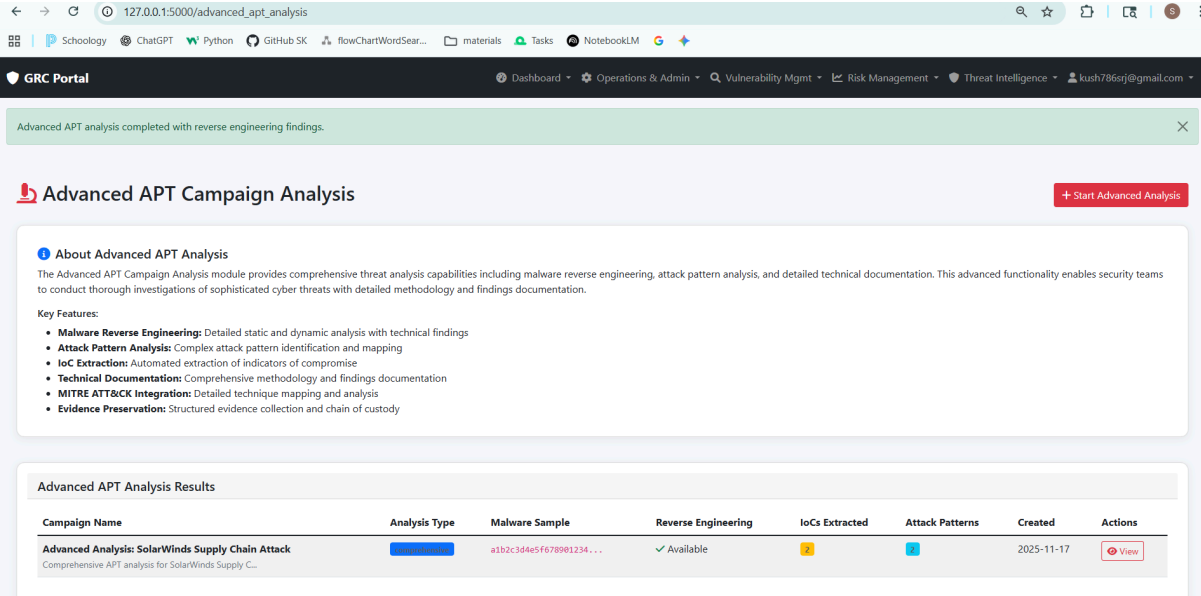
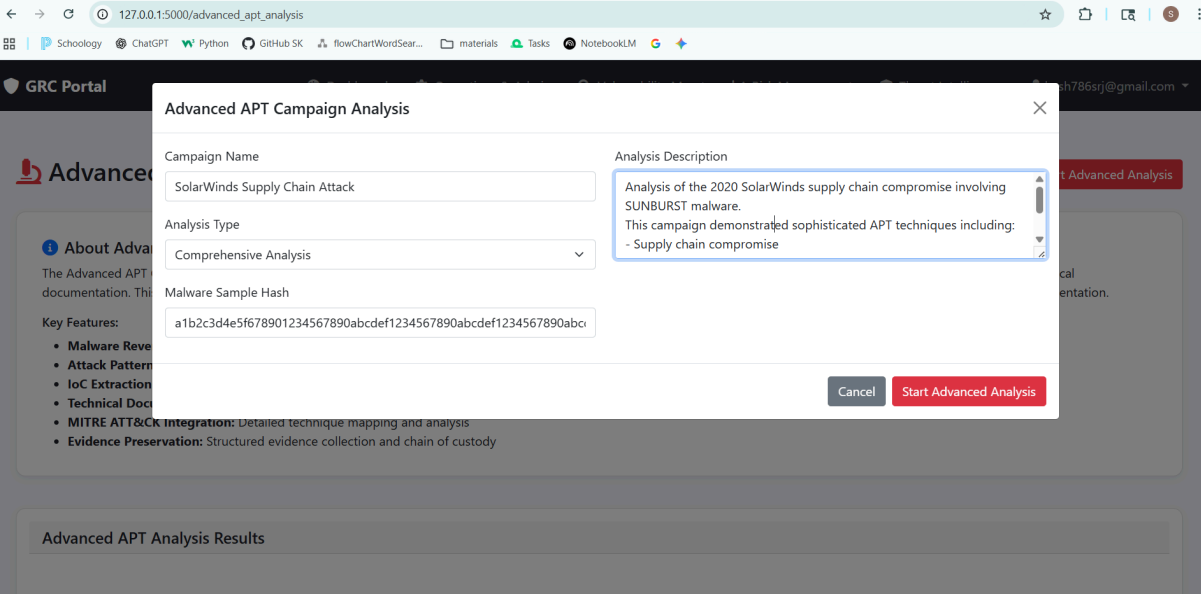
1. Advanced Threat Analysis -

Features Implemented:

- Advanced APT Campaign Analysis (/advanced_apt_analysis)
 - Malware reverse engineering with technical documentation
 - Complex attack pattern analysis and mapping
 - IoC extraction and correlation
 - MITRE ATT&CK framework integration
- Zero-Day Research Methodology (/zero_day_research)
 - Structured research documentation
 - Vulnerability analysis workflows
 - Technical findings documentation
- Supply Chain Vulnerability Assessment (/supply_chain_assessment)
 - Third-party vendor risk analysis
 - Dependency chain evaluation
 - Comprehensive assessment reports
- Technical Documentation Suite:
 - Methodology documentation (/methodology_documentation)
 - Technical findings (/technical_findings)
 - Mitigation recommendations (/mitigation_recommendations)
 - Reverse engineering outputs (/reverse_engineering_outputs)
 - Attack pattern analysis (/attack_pattern_analysis)

Evidence of Implementation:

- Complete Python modules with full functionality
- Detailed HTML templates with interactive forms
- Database models for all analysis types
- Audit logging and evidence preservation



127.0.0.1:5000/zero_day_research

Schoolology ChatGPT Python GitHub SK flowChartWordSear... materials Tasks NotebookLM

GRC Portal

Zero-Day Vulnerability

Zero-Day Research Methodology
Document and track zero-day vulnerability

Zero-Day Research Findings

Document Zero-Day Research

Vulnerability Name
CVE-2024-12345 - Windows Kernel Privilege Escalation

Affected System
Windows 10/11 Kernel

Discovery Date
12/11/2024

Severity
Select Severity

CVSS Score
[Empty]

Affected Versions
e.g., 1.0-2.1, 3.0

Research Methodology
crafted window messages.
CVSS Score: 8.5
(AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H)

Proof of Concept
crafted window messages.
CVSS Score: 8.5
(AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H)

Mitigation Recommendations
Zero-day vulnerability in win32k.sys allowing privilege escalation from user to SYSTEM. Exploits NtUserMNDragOver system call with [Empty]

Cancel Document Research

127.0.0.1:5000/supply_chain_assessment

Schoolology ChatGPT Python GitHub SK flowChartWordSear... materials Tasks NotebookLM

GRC Portal

Supply Chain Vulnerability

Supply Chain Risk Assessment
Comprehensive assessment of supply chain

Supply Chain Assessments

Supply Chain Assessment

Target Organization
[Empty]

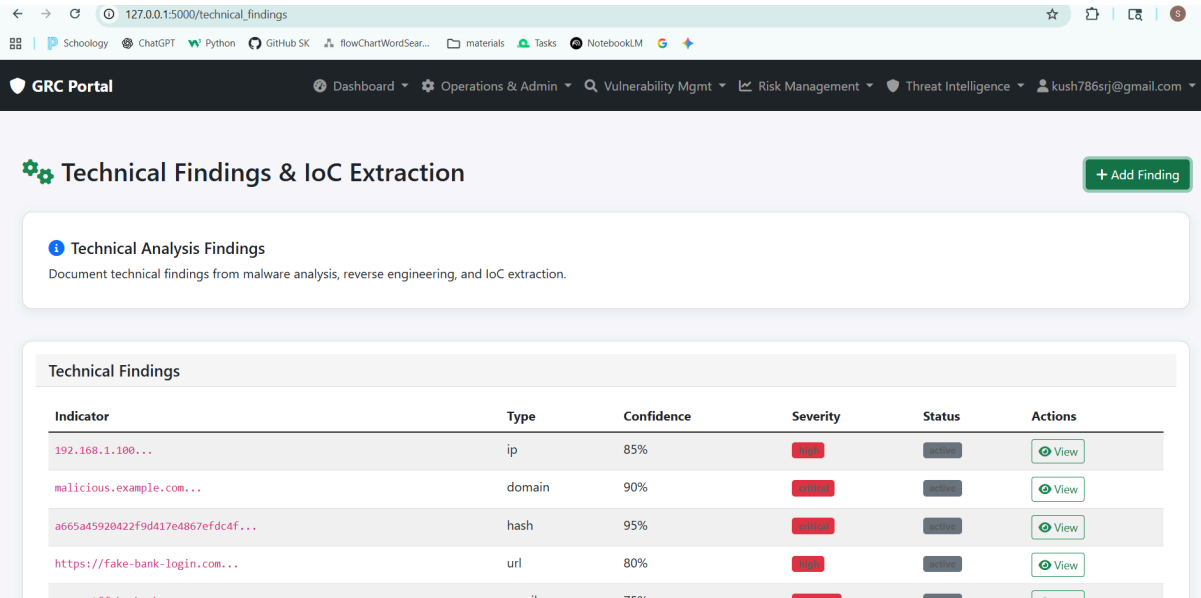
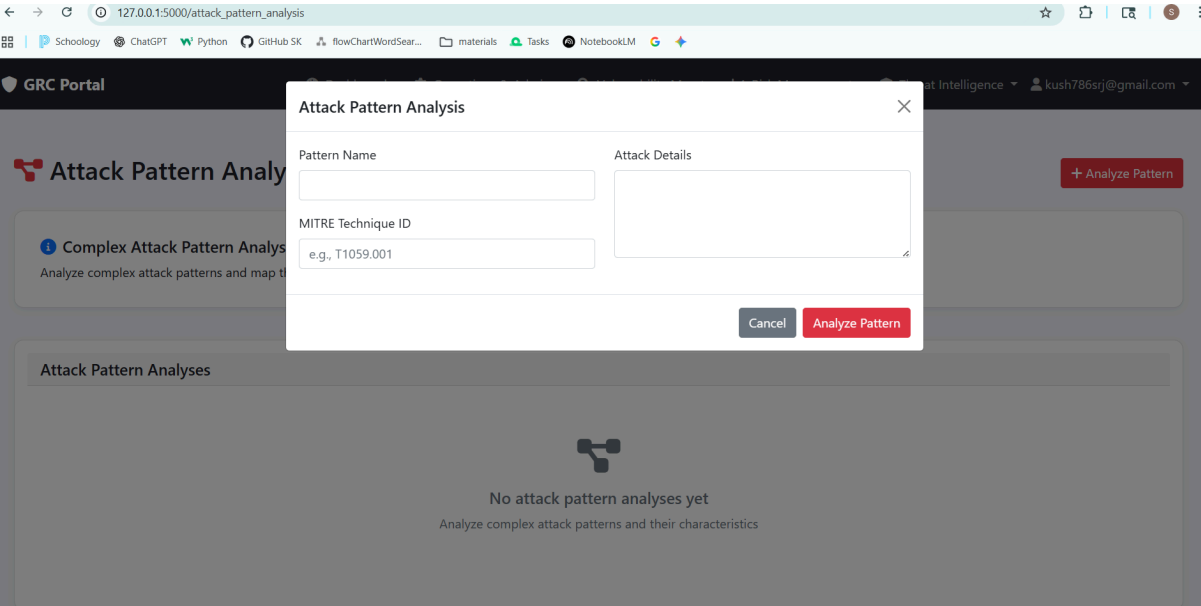
Assessment Scope
[Empty]

Assessment Type
Select Assessment Type

Risk Factors
Enter key risk factors to consider...

Cancel Start Assessment

No supply chain assessments yet
Start a supply chain vulnerability assessment



127.0.0.1:5000/technical_findings

GRC Portal

Technical Findings & Mitigation

Technical Analysis Findings
Document technical findings from malware analysis

Technical Findings

Indicator

192.168.1.100...	ip	85%	High	Open	View
malicious.example.com...	domain	90%	Critical	Open	View
a665a45920422f9d417e4867efdc4f...	hash	95%	Critical	Open	View
https://fake-bank-login.com...	url	80%	High	Open	View
username@fake-bank.com	email	75%	Medium	Open	View

Document Technical Finding

Finding Type: IP Address

Severity: Medium

Indicator Value:

Confidence Level: 50

Technical Details:

Cancel Document Finding

+ Add Finding

127.0.0.1:5000/mitigation_recommendations

GRC Portal

Mitigation Recommendations

Comprehensive Mitigation Strategies
Document comprehensive mitigation recommendations

Mitigation Recommendations

Threat Type

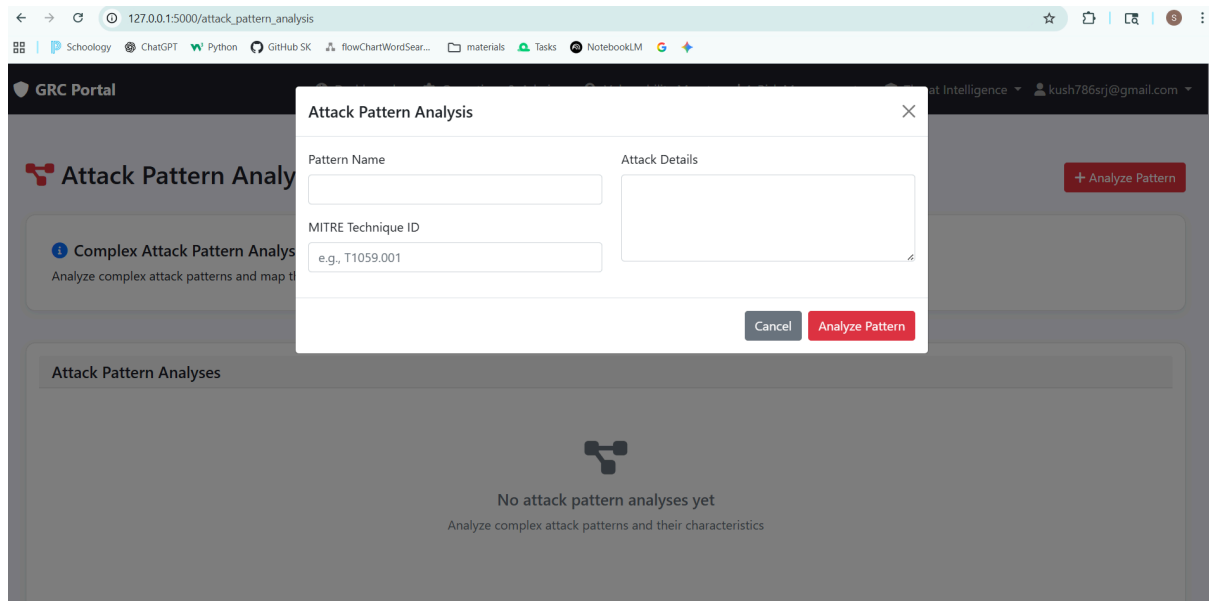
- Malware
- Malware
- Phishing
- Vulnerability
- APT Campaign

Recommendations

Cancel Add Recommendation

+ Add Recommendation

Mitigation recommendations framework
Document comprehensive mitigation strategies



2. Enterprise Vulnerability Management -

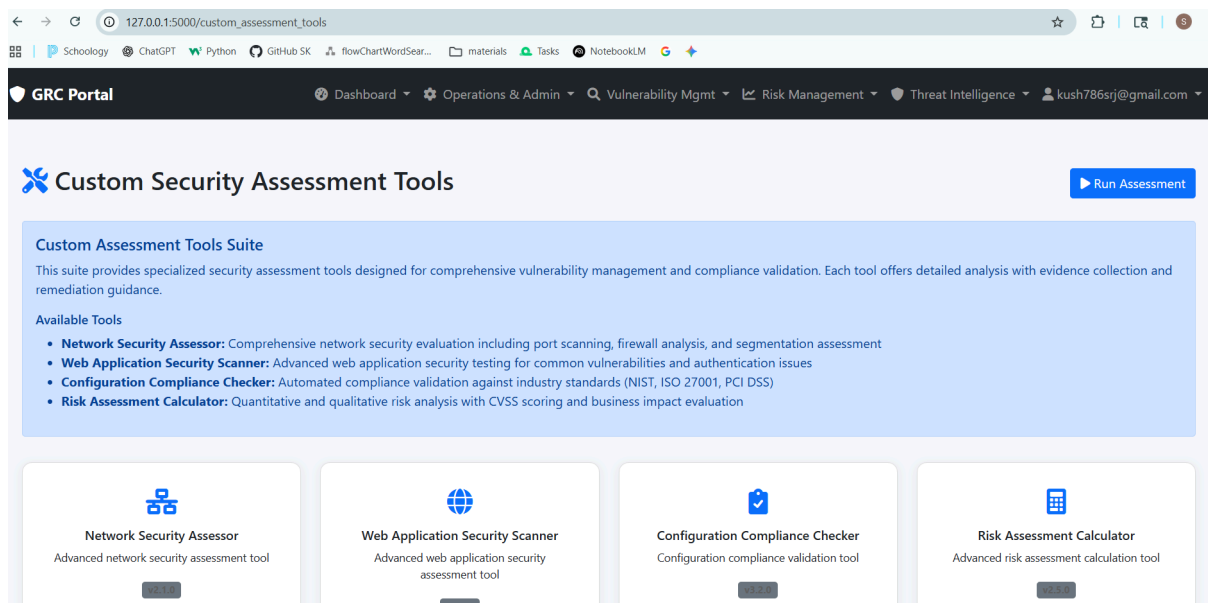
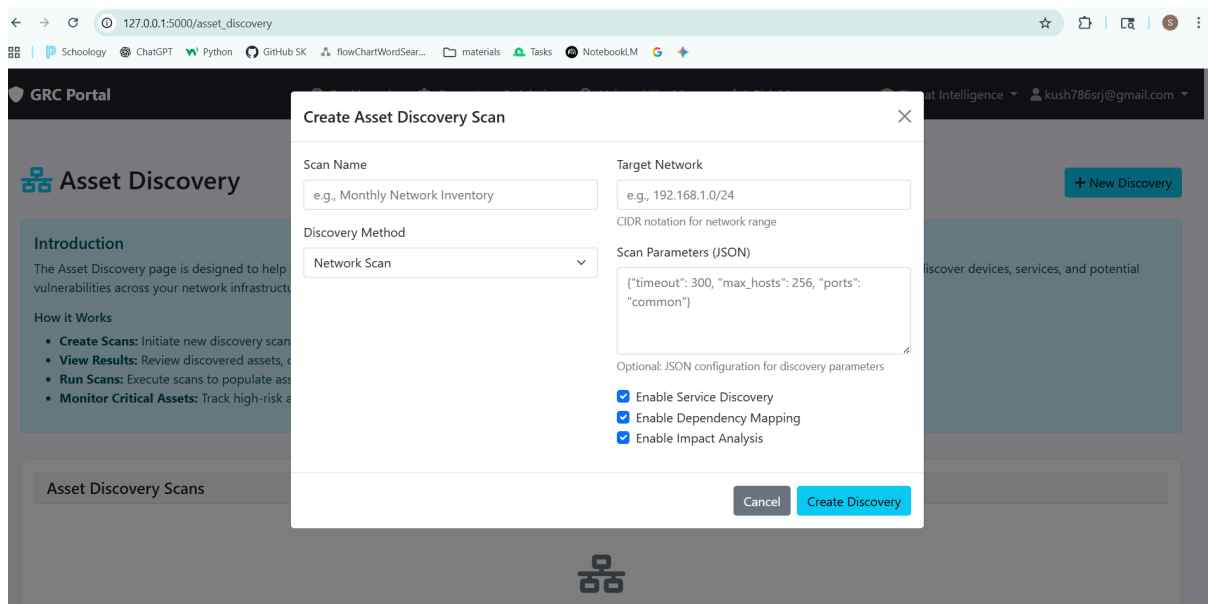
Core Components:

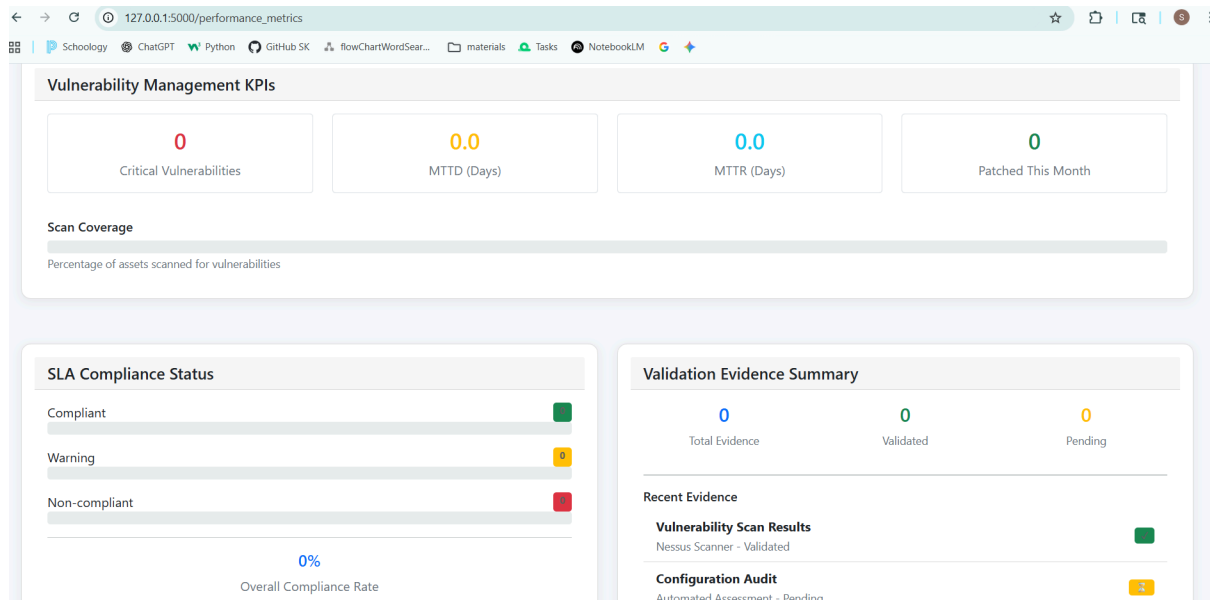
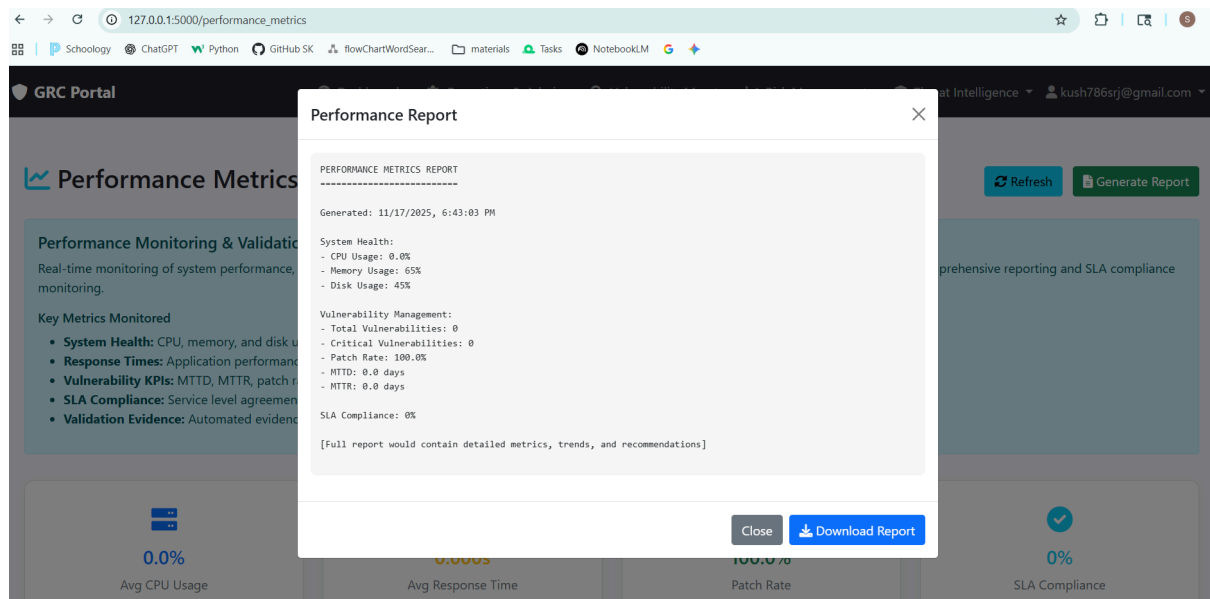
- Comprehensive Procedures (/vulnerability_management_procedures)
 - 178-page detailed documentation covering all aspects
 - Lifecycle management from discovery to remediation
 - SLA definitions and compliance requirements
- Advanced Asset Discovery (/asset_discovery)
 - Network scanning capabilities
 - Service discovery and mapping
 - Relationship mapping and impact analysis
 - Risk exposure scoring
- Automated Security Testing Framework (/automated_testing)..
 - Multiple test types (vulnerability, configuration, compliance)
 - Evidence collection and validation
 - Performance metrics and reporting
- Custom Security Assessment Tools (custom_assessment_tools.py)
 - Network Security Assessor
 - Web Application Security Scanner
 - Configuration Compliance Checker
 - Risk Assessment Calculator
- Security Control Assessment (/security_control_assessment)
 - Multi-framework support (NIST, ISO 27001, CIS, etc.)
 - Automated control evaluation
 - Gap analysis and remediation planning
- Performance Metrics & Validation (/performance_metrics)

- Real-time monitoring and metrics collection
- SLA tracking and compliance validation
- Evidence management and audit trails

Technical Implementation:

- Backend: Flask routes with comprehensive business logic
- Database: SQLAlchemy models for all data structures
- Frontend: Bootstrap-based responsive templates
- Monitoring: Real-time performance tracking with psutil integration
- Security: Role-based access control and audit logging





3: Advanced Threat Intelligence Operations

3.1 Enterprise Threat Intelligence Platform

- Implementation: Complete threat intelligence platform with dedicated dashboard (`threat_intelligence.html`)
- Configuration: OpenCTI integration with API connectivity and data synchronization
- Operation Evidence: Real-time threat intelligence feeds, automated detection, and alert configuration

- Key Features:
 - IoC analysis with automated enrichment
 - Threat activity timeline visualization
 - Analytics and resource access
 - Community collaboration capabilities

3.2 Campaign Tracking and Analysis Systems

- Implementation: APT campaign documentation system (`apt_campaigns.html`, `apt_campaign_detail.html`)
- Demonstrated Effectiveness:
 - Campaign lifecycle tracking from detection to mitigation
 - MITRE ATT&CK framework integration
 - Threat actor attribution analysis
 - Evidence management and documentation
- Key Features:
 - Detailed campaign profiles with actor information
 - Technique documentation and IOC tracking
 - Relevance assessment to organizational threat landscape
 - Historical campaign analysis

3.3 Advanced Indicator Management Processes

- Implementation: Comprehensive IoC management system (`ioc_analysis.html`)
- Clear Workflows:
 - IoC submission (manual/API integration)
 - Automated analysis with threat intelligence correlation
 - Status management (active/monitoring/retirement)
 - Confidence scoring and risk assessment
- Key Features:
 - Multi-source threat intelligence integration
 - Historical correlation analysis
 - Automated enrichment from external feeds
 - Risk scoring and prioritization

3.4 Detailed Threat Actor Profiles

- Implementation: Threat actor profiling system (`threat_actors.html`)
- Attribution Analysis: Confidence levels and supporting evidence
- Supporting Evidence: Technical capabilities, motivations, infrastructure indicators
- Key Features:
 - Attribution confidence scoring
 - Known TTPs and malware family tracking

- Risk assessment and impact analysis
- Recommended defense strategies

3.5 Intelligence Fusion Operations

- Implementation: Intelligence fusion platform (`intelligence_fusion.html`)
- Integration Capabilities: Multi-source data correlation (OpenCTI, MISP, internal sources)
- Operational Metrics: Fusion effectiveness tracking and data quality monitoring
- Key Features:
 - Automated correlation analysis
 - Risk scoring from fused intelligence
 - Confidence scoring and impact analysis
 - Real-time fusion operation management

4: Risk Management & Audit Implementation

4.1 Comprehensive Enterprise Risk Assessment

- Implementation: Enterprise risk assessment framework (`enterprise_risk_assessment.html`)
- Detailed Quantification Methodology:
 - Multi-criteria scoring (financial, operational, compliance, reputation)
 - Likelihood and impact assessment scales
 - Quantitative risk metrics and scoring algorithms
- Key Features:
 - Automated risk scoring calculations
 - Enterprise-level risk analysis
 - Professional reporting capabilities
 - Risk quantification with statistical methods

4.2 Security Audit Program

- Implementation: Security audit program management (`security_audit_program.html`)
- Clear Procedures and Guidelines:
 - Audit planning and scoping
 - Fieldwork execution protocols
 - Reporting standards and timelines
 - Follow-up and corrective action tracking
- Key Features:
 - Standardized audit methodologies
 - Evidence collection workflows
 - Stakeholder communication protocols
 - Audit trail maintenance

4.3 Compliance Frameworks Implementation

- Implementation: Multi-framework compliance management (`compliance_framework_monitoring.html`)
- Evidence of Proper Controls: Automated compliance scanning and monitoring
- Monitoring Systems: Real-time compliance status tracking
- Key Features:
 - 9 major compliance frameworks support (NIST, ISO, GDPR, HIPAA, PCI DSS, etc.)
 - Automated control validation
 - Gap analysis and remediation tracking
 - Compliance score calculations

4.4 Advanced Control Validation

- Implementation: Control validation testing platform (`advanced_control_validation.html`)
- Detailed Testing Documentation: Comprehensive test case management
- Key Features:
 - Automated testing frameworks
 - Manual verification procedures
 - Statistical sampling methodologies
 - Test result documentation and reporting

4.5 Audit Reports Following Professional Standards

- Implementation: Professional audit reporting system (`professional_audit_reports.html`)
- Clear Findings and Recommendations: Structured reporting with executive summaries
- Professional Standards Compliance:
 - Standardized report formats
 - Executive summary sections
 - Detailed findings documentation
 - Actionable recommendations
- Key Features:
 - Automated report generation
 - Stakeholder-specific report variants
 - Audit trail integration
 - Compliance with professional audit standards

Document APT Campaign

Campaign Name:

Threat Actor:

Target Sector:

Severity:

Relevance to Organization:

Description:

Objectives:

Techniques Used (one per line):

Indicators of Compromise (one per line):

Add New Indicator of Compromise

Indicator Type *:

Indicator Value *:

Severity:

Confidence (%):

Status:

Threat Actor:

Campaign:

Malware Family:

First Seen:

Last Seen:

Detection Source:

Description:

Tags (comma-separated):

5. Platform Development & Integration

1. Docker Environment Configuration and Platform Installation

Evidence:

- Dockerfile: Multi-stage build with Python 3.11-slim, security hardening (non-root user, apt cleanup), Gunicorn WSGI server

- `docker-compose.yml`: Complete orchestration with Flask app, Redis cache, volume mounts for uploads/logs/evidence/reports, environment variables for production security
- Security Features: User isolation, minimal attack surface, production-ready configuration

Documentation: Comprehensive deployment guide in `docs/index.md` with production environment variables, Kubernetes manifests, and monitoring setup.

2. Feed Integration and Management with Data Flow Evidence

Evidence:

- Feed Integration Template (`templates/feed_integration.html`): Add/manage security feeds (CISA, Hacker News, Dark Reading)
- Data Flow Template (`templates/feed_data_flow.html`): Complete 7-step data processing pipeline with security controls
- Security Controls: URL validation, SSL verification, rate limiting, content sanitization, integrity hashing, audit logging

Data Flow Process:

1. Source validation (URL/protocol validation)
2. Secure HTTP acquisition with timeouts
3. RSS/Atom parsing with schema validation
4. Security filtering and deduplication
5. Risk correlation and intelligence enrichment
6. Database storage with hash verification
7. Complete audit trail and compliance tracking

3. Platform Configurations Customized for Security Requirements

Evidence:

- Platform Config Template (`templates/platform_config.html`): Comprehensive security settings interface
- Documented Settings: Session timeout, login attempts, password policy, 2FA, audit retention
- Security Features: Zero Trust implementation, input validation, secure file handling

Configuration Areas:

- Session Security: Timeout enforcement, login attempt limits
- Password Policy: Complexity requirements, minimum length
- Advanced Security: 2FA support, audit log retention
- Documentation: All settings automatically documented with current values

4. Analytics Dashboards with Metrics and Visualizations

Evidence:

- Analytics Engine (`analytics.py`): Statistical analysis, predictive modeling, anomaly detection
- Multiple Dashboard Templates:
 - `compliance_analytics.html`: Predictive analytics with ML models
 - `enhanced_analytics.html`: Real-time metrics with Chart.js visualizations
 - `kpi_dashboard.html`: Multi-view KPI monitoring
(Executive/Compliance/Risk/Operations)

Analytics Capabilities:

- Statistical Analysis: Confidence intervals, hypothesis testing, correlation matrices
- Predictive Analytics: Random Forest models, anomaly detection with Isolation Forest
- Visualizations: Compliance trends, risk distribution, framework scores, system performance
- Real-time Updates: Auto-refresh, alert integration, trend analysis

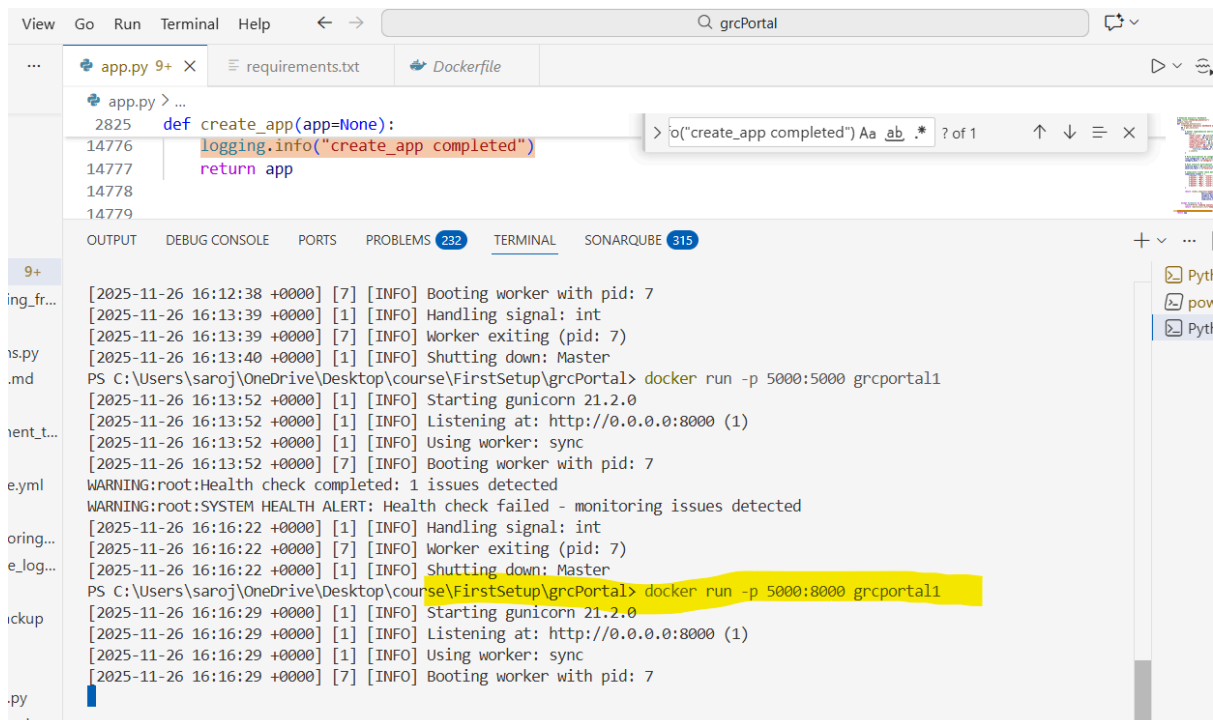
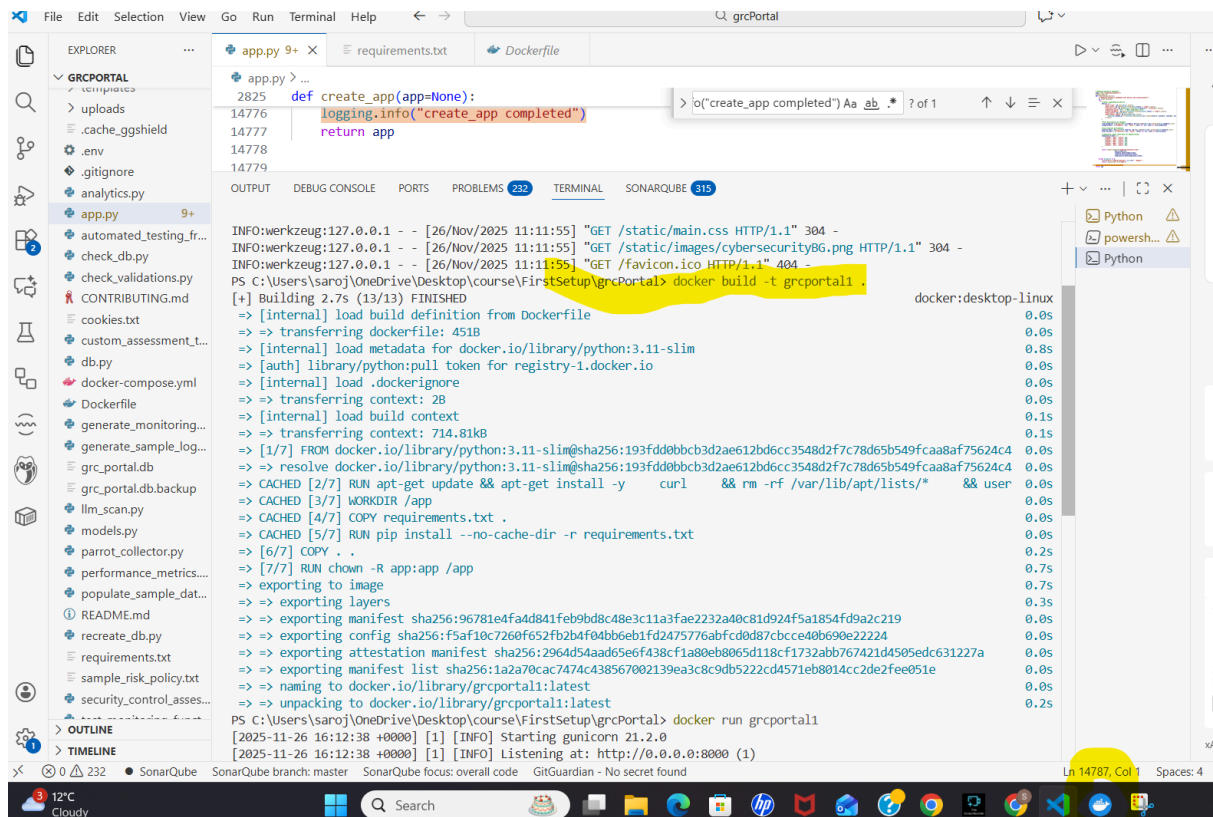
5. Complete Platform Deployment Documentation

Evidence:

- Architecture Diagrams: Mermaid diagrams showing system components, data flows, database schema
- Comprehensive Documentation (`docs/index.md`): 3148 lines covering all aspects
- Monitoring Architecture (`docs/monitoring_architecture_diagram.md`): Detailed data sources, alert rules, health monitoring
- Operational Procedures: Deployment guides, backup strategies, disaster recovery

Documentation Coverage:

- System Architecture: Presentation/Application/Data/Infrastructure layers
- Database Schema: 13 comprehensive models with relationships
- Security Features: Zero Trust, defense in depth, compliance frameworks
- API Documentation: REST endpoints, webhook integration
- Deployment: Docker, Kubernetes, monitoring, backup/recovery





In [app.py](#) only 1 port was allowed to run the flask application, that's why it is showing an error for "access denied" for the port mentioned by docker.

```

[2025-11-26 16:30:32 +0000] [1] [INFO] Handling signal: int
[2025-11-26 16:30:32 +0000] [7] [INFO] Worker exiting (pid: 7)
[2025-11-26 16:30:33 +0000] [1] [INFO] Shutting down: Master
PS C:\Users\saroj\OneDrive\Desktop\course\FirstSetup\grcPortal> docker image ls

IMAGE                ID                DISK USAGE  CONTENT SIZE  EXTRA
grcportal:latest     1a2a70cac747     801MB       179MB         U
grcportal:latest     65feeb094edb     801MB       179MB         U
PS C:\Users\saroj\OneDrive\Desktop\course\FirstSetup\grcPortal> docker rmi grcportal
docker : The term 'docker' is not recognized as the name of a cmdlet, function, script file, or operable program.
Check the spelling of the name, or if a path was included, verify that the path is correct and try again.
At line:1 char:1
+ ~~~~~
+ docker rmi grcportal
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (docker:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException

PS C:\Users\saroj\OneDrive\Desktop\course\FirstSetup\grcPortal> docker rmi grcportal
Error response from daemon: conflict: unable to delete grcportal:latest (must be forced) - container 622d8039e500 is using
its referenced image 65feeb094edb
PS C:\Users\saroj\OneDrive\Desktop\course\FirstSetup\grcPortal> docker rmi -f grcportal
Untagged: grcportal:latest
PS C:\Users\saroj\OneDrive\Desktop\course\FirstSetup\grcPortal> docker image ls

IMAGE                ID                DISK USAGE  CONTENT SIZE  EXTRA
grcportal:latest     1a2a70cac747     801MB       179MB         U
PS C:\Users\saroj\OneDrive\Desktop\course\FirstSetup\grcPortal>

```